

Mobile and Wireless security

Prof. Tewfiq EL MALIKI

2025

Comparaison TCP vs SCTP face au SYN Flooding

Critère	TCP (Vulnérable)	SCTP (Protégé)
Allocation mémoire	Dès réception de SYN	Rien n'est stocké avant COOKIE-ECHO
IP spoofing	L'attaquant n'a pas besoin de réponse	L'attaquant doit recevoir et renvoyer le cookie
Table de connexions saturée ?	Oui (SYN Flooding efficace)	Non (le serveur ne garde rien en mémoire)
Protection intégrée ?	Non (TCP doit utiliser SYN Cookies)	Oui (Mécanisme du cookie SCTP intégré)

Multihoming et détection de plusieurs connexion de la même adresse IP

Contents

- OPEN SYSTEM AUTHENTICATION SECURITY
- WIRED EQUIVALENT PRIVACY (WEP)
- ROBUST SECURITY NETWORK (RSN)

Temporal Key Integrity protocol (TKIP)

Counter Mode with CBC-MAC (CCMP)

Key Management and Establishment

Authentication Protocols

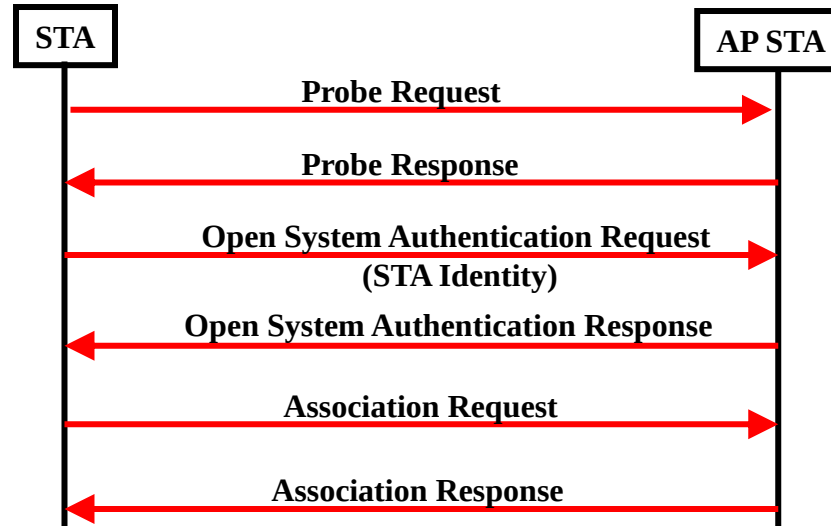
Histoire

WIRED EQUIVALENT PRIVACY

A solid red horizontal bar spanning the width of the slide at the bottom.

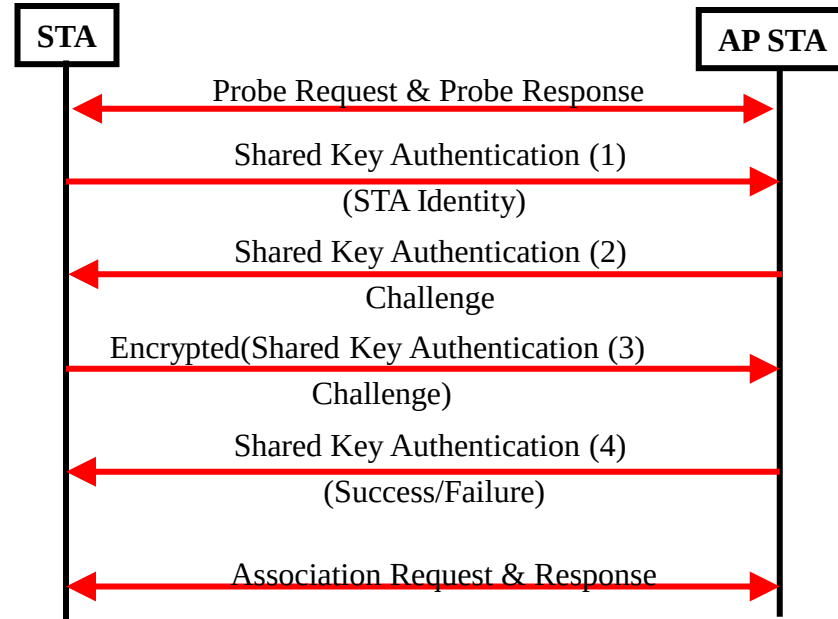
1. Open System Authentication

- Establishing the IEEE 802.11 association with no authentication
- Like switch cable connection



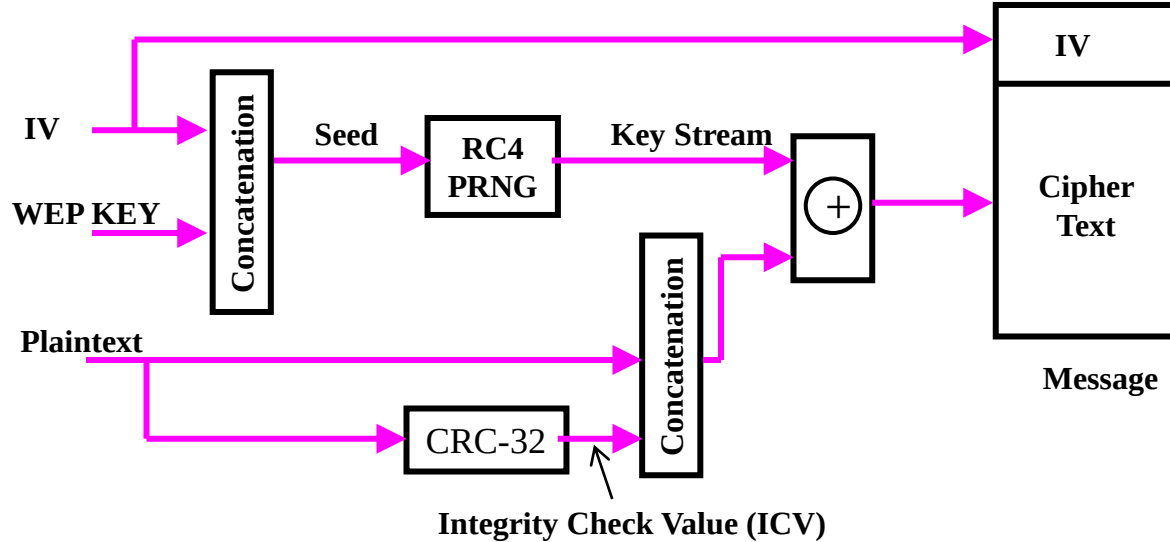
Wired Equivalent Privacy(WEP)

- WEP uses shared key authentication (2004)



Wired Equivalent Privacy Falws

- WEP Encryption uses RC4 stream cipher



WEP

- Several major problems in WEP security
 - The IV used to produce the RC4 stream is only 24-bit long
 - The short IV field means that the same RC4 stream will be used to encrypt different texts
 - IV collision
 - Statistical attacks can be used to recover the plaintexts due to IV collision
 - The CRC-32 checksum can be easily manipulated to produce a valid integrity check value (ICV) for a false message

Evolution

WI-FI PROTECTION ACCESS WPA

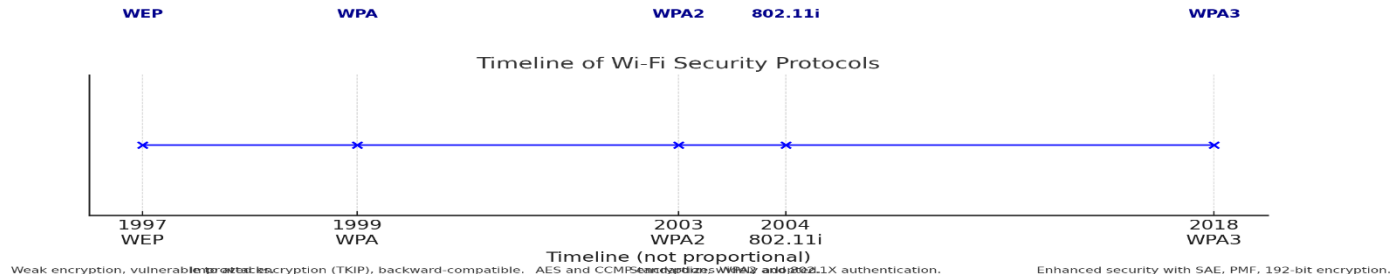


WPA Overview

- Wi-Fi Protected Access (WPA)
 - Security Protocol developed after WEP's vulnerabilities exploited and successfully attacked
 - Collaborative effort between the Wi-Fi Alliance and (IEEE)
 - A transit solution until the development of (802.11i/WPA2)

Timeline of Wifi security

- 1997 - WEP (Wired Equivalent Privacy):
 - The first Wi-Fi security protocol with weak encryption, vulnerable to attacks.
- 1999 - WPA (Wi-Fi Protected Access):
 - Introduced TKIP to improve encryption while maintaining backward compatibility with WEP.
- 2003 - WPA2 (Wi-Fi Protected Access II):
 - Adopted AES and CCMP for stronger encryption, becoming the most widely used standard.
- 2004 - 802.11i Standard:
 - Provided full implementation of WPA2 security with advanced authentication methods using 802.1X.
- 2018 - WPA3 (Wi-Fi Protected Access III):
 - Enhanced security features including SAE, Protected Management Frames (PMF), and support for 192-bit encryption.



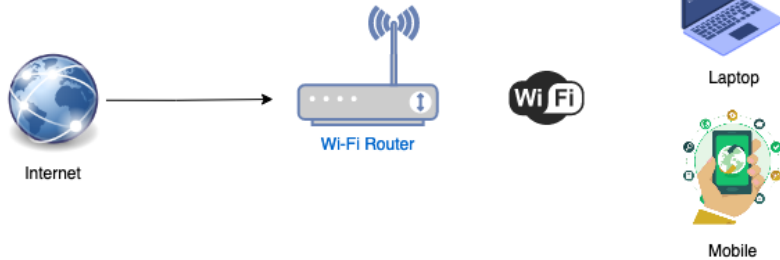
Terminology



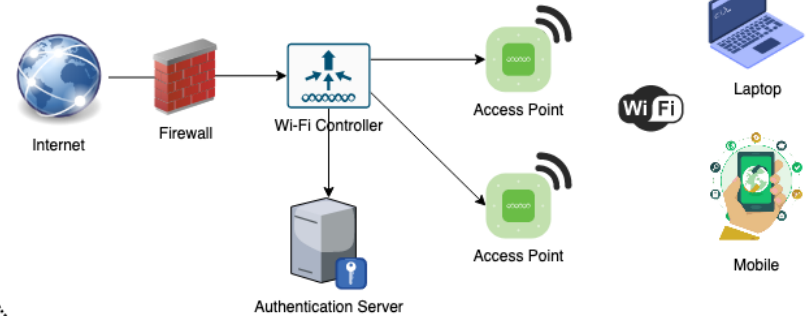
- **STA wireless client is officially called a station (STA)**
- AP Access Point
- AS Authentication Server
- With 802.1X, we have the supplicant, authenticator, and authentication server.
- With a wireless network, the wireless client is the supplicant, and the Access Point (AP) is the authenticator.

Personal vs Enterprise

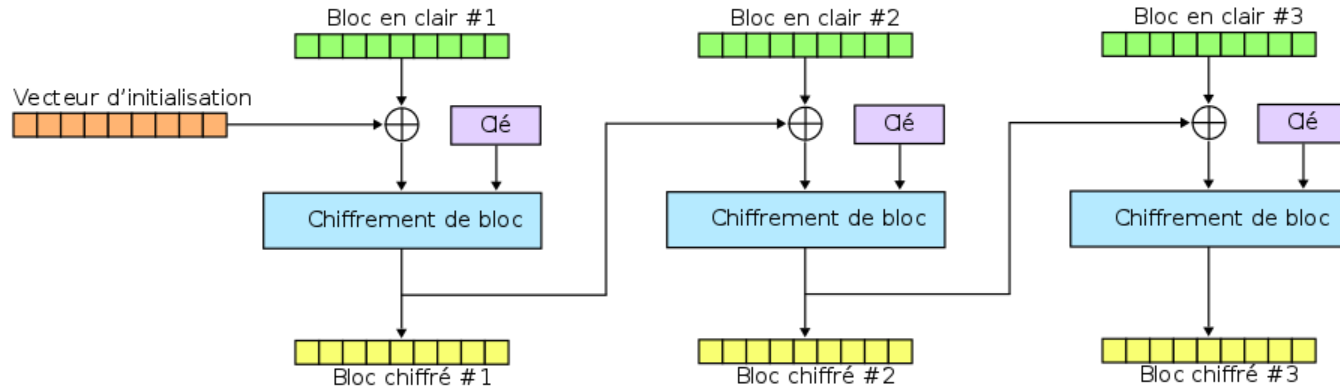
WPA2-Personal



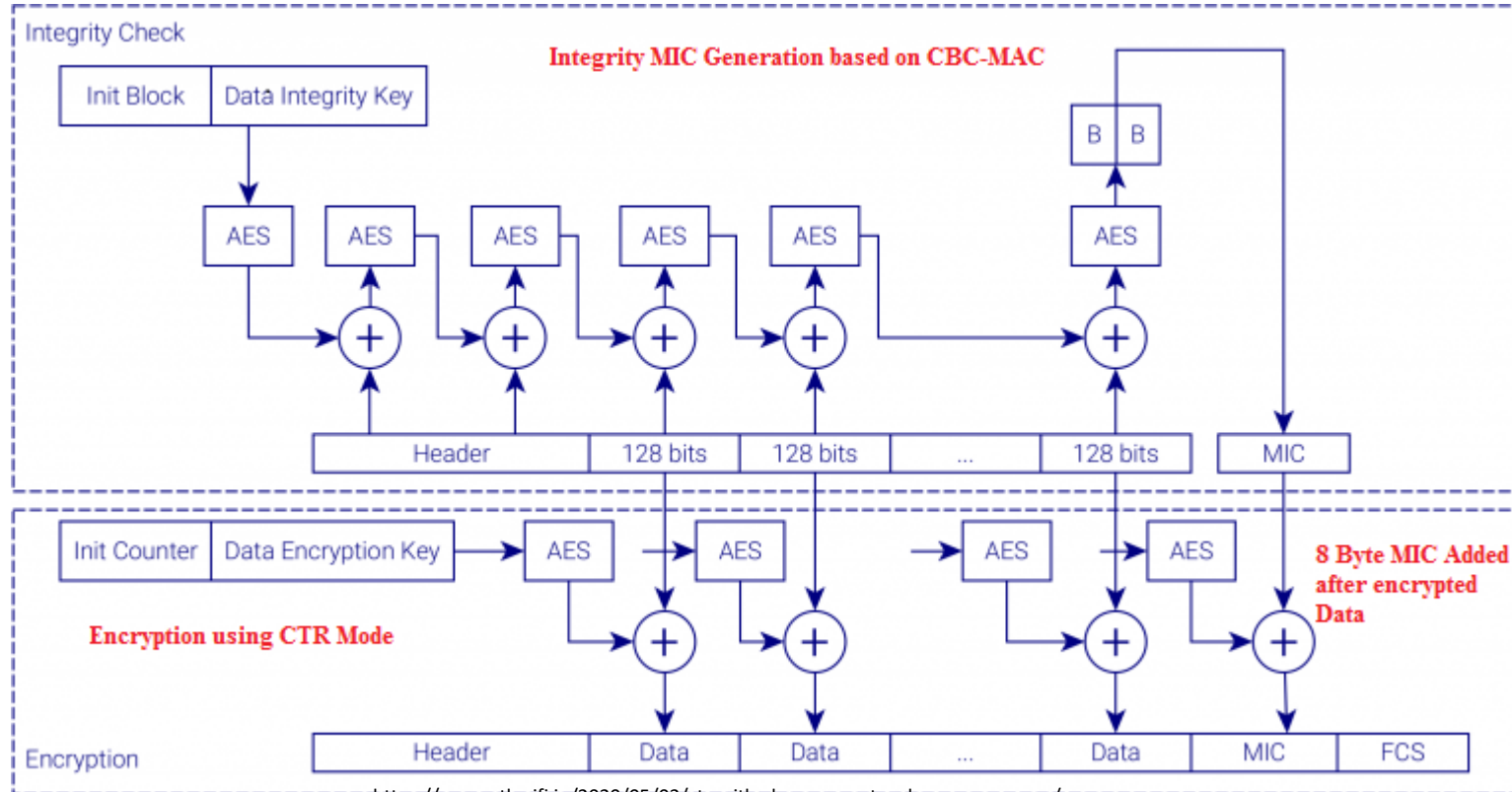
WPA2-Enterprise



CBC « Cipher Block Chaining »: enchaînement de blocs



CCMP AES Encryption/MIC



Robust Security Network (RSN)

- 802.11i defines a set of features to establish a RSN association (RSNA) between stations (STAs)
 - Enhanced data encapsulation mechanism
 - CCMP Counter Mode with Cipher Block Chaining Message Authentication Code Protocol : utilize AES
 - Optional: TKIP
 - Key management and establishment
 - Four-way handshake and group-key handshake
 - Enhanced authentication mechanism for STAs
 - Pre-shared key (PSK); IEEE 802.1x/EAP methods

WPA Overview 1

- WPA strengthened WEP by:
 - Including authentication using 802.1X framework (Enterprise : Radius) or a passphrase (home systems)
 - Creating a key hierarchy out of the master key
 - Doubling the size of the initialization vector (IV) used during encryption
 - Including a more robust data integrity algorithm (Michael)

WPA Overview 2

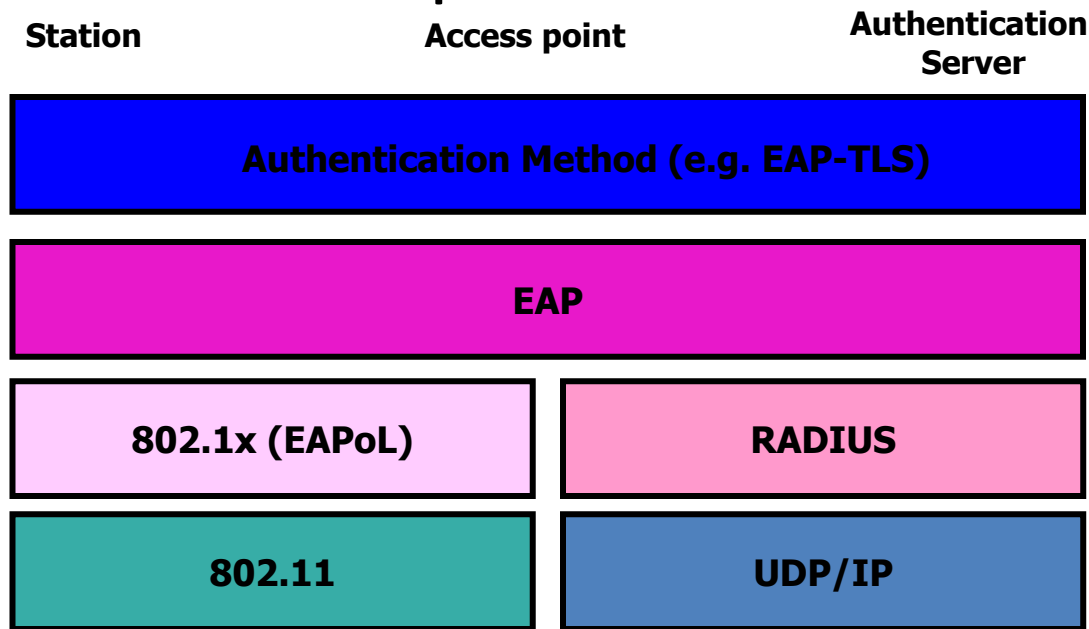
- A session consists of:
 - Authentication of the client to the access point (802.1X/passphrase)
 - 4-way handshake to exchange key values and generate the key hierarchy
 - Data session to send encrypted information using the Temporal Key Integrity Protocol (TKIP)
 - RC4 for encryption
 - Michael for integrity checking

802.1x

- Port based Network access control protocol
 - Mutual authentication
- Based on 3 elements
 - **Supplicant** A software client running on the Wi-Fi workstation.
 - **Authenticator** The Wi-Fi access point.
 - **Authentication Server** An authentication database, radius or diameter
- It uses EAP (an authentication framework)
 - Methods defined in RFCs such as EAP-MD5, EAP-POTP, EAP-GTC, EAP-TLS, EAP-IKEv2, EAP-SIM, EAP-AKA, and EAP-AKA'.
- Operates at network layer not data link layer

Authentication Protocols

- Authentication components

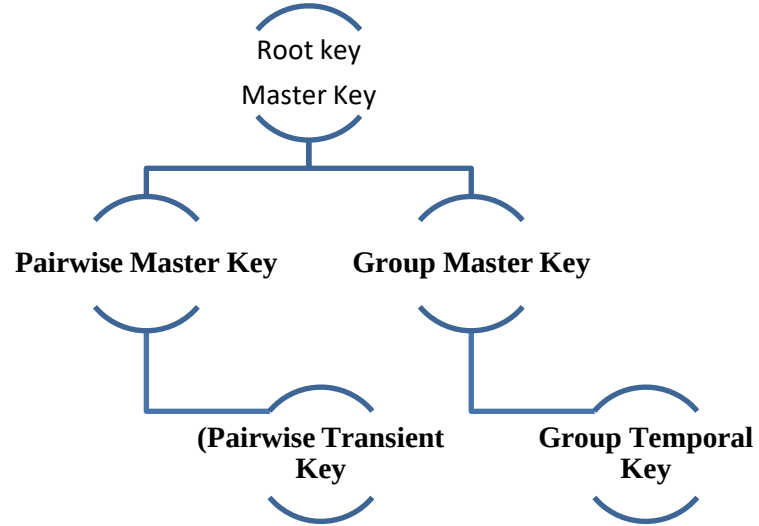


RADIUS and Diameter

- Both are encapsulating EAP messages.
- Used by Network Access Server (NAS) devices
- Forward EAP packets between IEEE 802.1X endpoints and AAA servers
- Facilitate IEEE 802.1X.

802.1X EAP Types Feature / Benefit	MD5 --- Message Digest 5	TLS --- Transport Level Security	TTLS --- Tunneled Transport Level Security	PEAP --- Protected Transport Level Security	FAST --- Flexible Authentication via Secure Tunneling	LEAP --- Lightweight Extensible Authentication Protocol
Client-side certificate required	no	yes	no	no	no (PAC)	no
Server-side certificate required	no	yes	yes	yes	no (PAC)	no
WEP key management	no	yes	yes	yes	yes	yes
Rogue AP detection	no	no	no	no	yes	yes
Provider	MS	MS	Funk	MS	Cisco	Cisco
Authentication Attributes	One way	Mutual	Mutual	Mutual	Mutual	Mutual
Deployment Difficulty	Easy	Difficult (because of client certificate deployment)	Moderate	Moderate	Moderate	Moderate
Wi-Fi Security	Poor	Very High	High	High	High	High when strong passwords are used

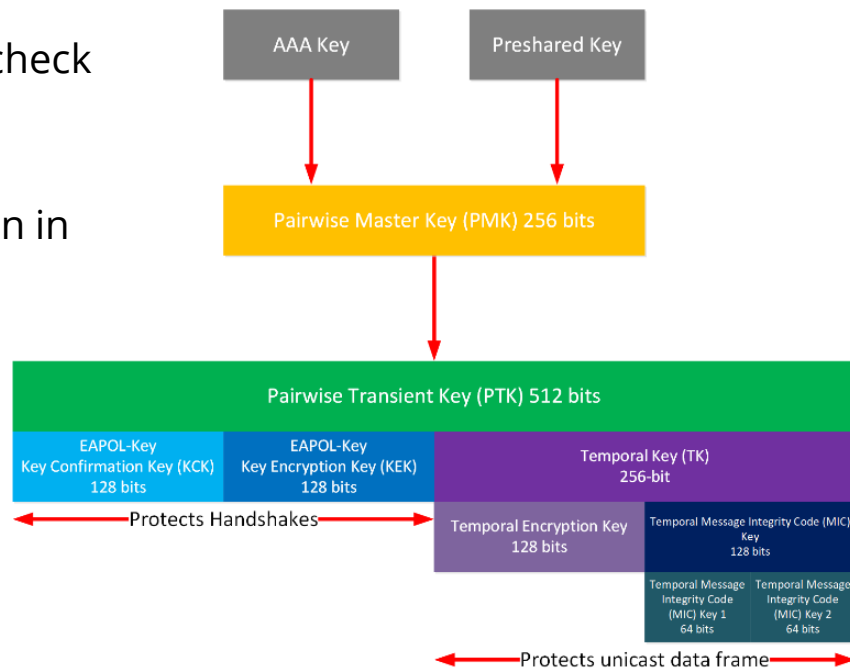
Clefs 802.1x



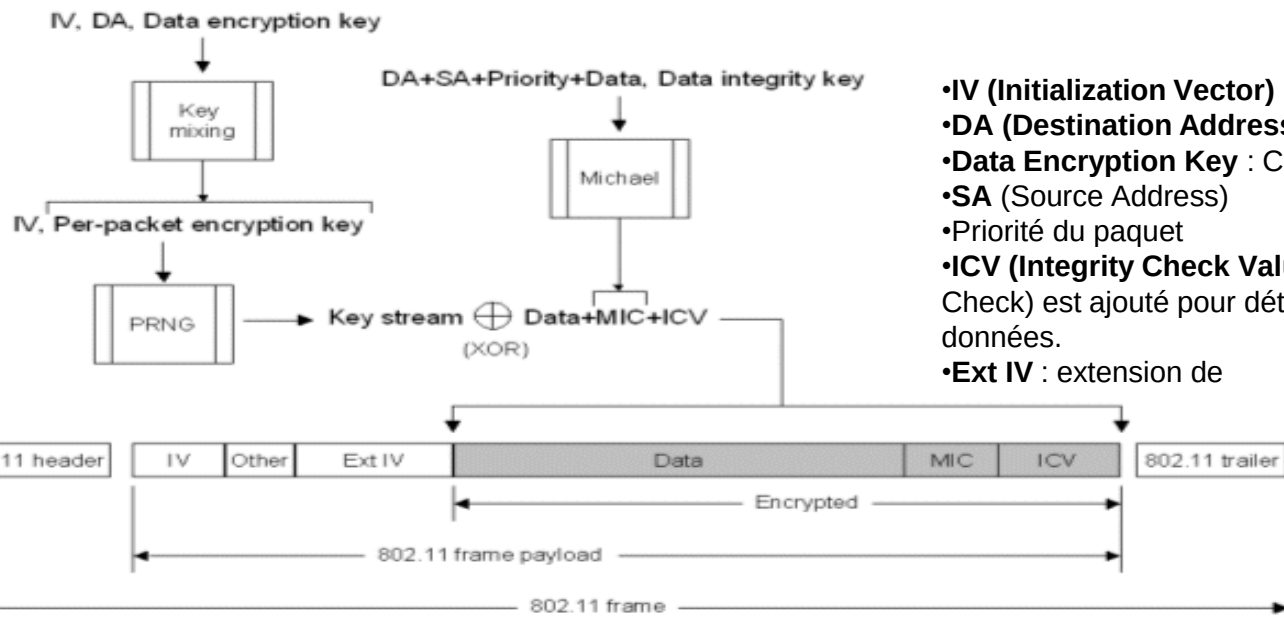
- **Root Key (Master Key)** : La clé principale à partir de laquelle toutes les autres clés sont dérivées.
- **PMK (Pairwise Master Key)** : Utilisée pour générer des clés pour les connexions unicast (entre deux appareils).
- **GMK (Group Master Key)** : Utilisée pour générer des clés pour les connexions multicast et broadcast.
- **PTK (Pairwise Transient Key)** : Clé transitoire utilisée pour le chiffrement des communications unicast.
- **GTK (Group Temporal Key)** : Clé temporaire utilisée pour le chiffrement des communications multicast et broadcast.
- **Encryption Keys (Session Keys)** : Clés finales utilisées pour le chiffrement des sessions actives.

PTK for TKIP

- It is 512 bits and partitioned :
- EAPOL-Key : Key Confirmation Key (KCK) integrity check
- EAPOL-Key : Key Encryption Key (KEK)
- Temporal Key (TK) : integrity checks and encryption in MSDUs
 - Temporal Encryption Key
 - Temporal Message Integrity Code (MIC) Key
 - Temporal MIC Key 1
 - Temporal MIC Key 2



WPA TKIP Encryption



- **IV (Initialization Vector)** : Valeur aléatoire pour chaque paquet.
- **DA (Destination Address)** : Adresse MAC de destination.
- **Data Encryption Key** : Clé de session dérivée du PMK.
- **SA (Source Address)**
- **Priorité du paquet**
- **ICV (Integrity Check Value)** : Un CRC (Cyclic Redundancy Check) est ajouté pour détecter d'éventuelles corruptions des données.
- **Ext IV** : extension de

Protection contre les attaques par rejouabilité : Grâce à l'IV dynamique, les attaques par injection sont plus difficiles.

Chiffrement plus robuste : Utilisation d'un **key stream dynamique** généré par un PRNG.

Fonctionnement de TKIP

1. Clé dynamique par paquet :

TKIP génère une clé unique pour chaque paquet transmis, ce qui rend les attaques basées sur la réutilisation des clés (comme celles affectant WEP) beaucoup plus difficiles.

2. Mélange de clé (Key Mixing):

Combine une clé maître (clé pré-partagée ou issue d'un serveur d'authentification) avec d'autres données pour produire des clés uniques.

3. Vecteur d'initialisation (IV) étendu :

Utilise un IV de 48 bits (au lieu de 24 bits dans WEP) pour éviter la répétition des clés et améliorer la résistance contre les attaques par injection.

4. Intégrité des messages (MIC - Message Integrity Check) :

Ajoute un contrôle d'intégrité au niveau des paquets pour détecter toute modification des données en transit.

Faiblesses de TKIP

- **Compatibilité héritée** : TKIP a été conçu pour être rétrocompatible avec le matériel existant basé sur WEP, mais cela a limité son niveau de sécurité.
- **Attaques modernes** : Des attaques comme **Beck-Tews** (2008) ont montré que TKIP reste vulnérable aux attaques cryptographiques.
- **Dépréciation** : En raison de ces vulnérabilités, TKIP est désormais considéré comme obsolète et n'est plus recommandé pour les réseaux modernes.
- Remplacement par CCMP :
 - **CCMP (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol)**, basé sur AES, a remplacé TKIP dans **WPA2** pour offrir une sécurité plus robuste.
 - Contrairement à TKIP, CCMP fournit un chiffrement et une intégrité beaucoup plus solides, éliminant les vulnérabilités de WEP et TKIP

WPA-2 and WPA-3

- WPA-2 -> 2004 IEEE 802.11i
 - Based on AES Encryption
 - WiFi Trade mark (after 2006)
- WPA-3 -> 2018
 - 128 bit Encryption in personal mode
 - 192 bit Encryption in Enterprise mode

WPA2 Overview

- Wi-Fi Protected Access 2
 - Security standard developed by the Wi-Fi Alliance and based on IEEE's 802.11i
 - Uses 4-way handshake, and key hierarchy as WPA
 - Replaces TKIP with the Advance Encryption Standard (AES) CCMP protocol
 - AES in Counter-Mode for encryption
 - AES in Cipher Block Chaining-Message Authentication Code (CBC-MAC) for integrity checking

Robust Security Network

WI-FI PROTECTION ACCESS WPA3

A solid red horizontal bar spanning the width of the slide at the bottom.

Purpose of enhanced authentication mechanisms

- Ensure **secure identification** of devices before granting network access.
- **Prevent unauthorized access** to the network.
- **Protect data privacy** and integrity during transmission.
- Address weaknesses in older protocols like **WEP**, **WPA**, and even **WPA2**.

Key Enhanced Authentication Mechanisms

- **WPA3 with SAE (Simultaneous Authentication of Equals):**
- **Description:** WPA3 replaces WPA2-PSK with **SAE**, a more secure method for key exchange.
- **How it works:**
 - SAE is a **password-authenticated key exchange (PAKE)** protocol that prevents offline dictionary attacks.
 - It uses a zero-knowledge proof, so the password is never transmitted over the network, reducing the risk of interception.
- **Benefit:** Provides stronger protection even when weak passwords are used.

Key Enhanced Authentication Mechanisms

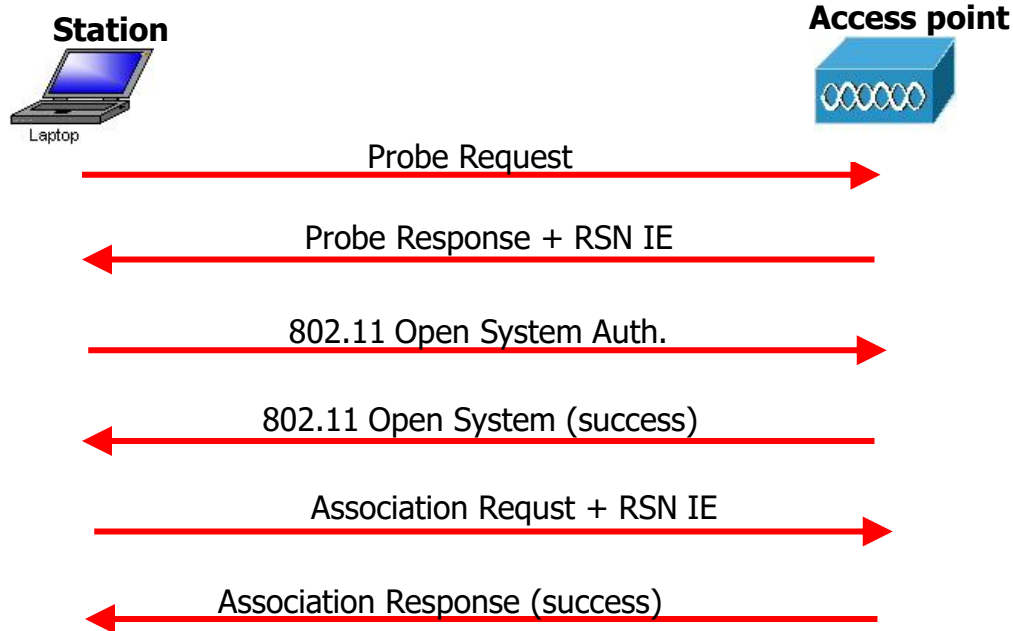
- **802.1X / EAP (Extensible Authentication Protocol):**
- **Description:** Often used in enterprise networks (WPA2-Enterprise or WPA3-Enterprise).
- **How it works:**
 - Uses the **802.1X** standard for port-based access control.
 - Supports multiple authentication methods, such as certificates, smart cards, and tokens.
 - Relies on a **RADIUS server** for centralized authentication.
- **Benefit:** Provides high security with mutual authentication between the STA and the network.

Key EAM suite

- **PMF (Protected Management Frames):**
 - **Description:** Ensures that management frames, such as disassociation or deauthentication requests, are authenticated and encrypted.
- **Opportunistic Wireless Encryption (OWE):**
 - **Description:** A replacement for **open Wi-Fi networks** that lack encryption.
 - **How it works:**
 - Encrypts traffic even in open networks without requiring a password.
 - Uses **Diffie-Hellman key exchange** to secure the communication.
- **Benefit:** Provides basic encryption without user intervention, making public Wi-Fi safer.

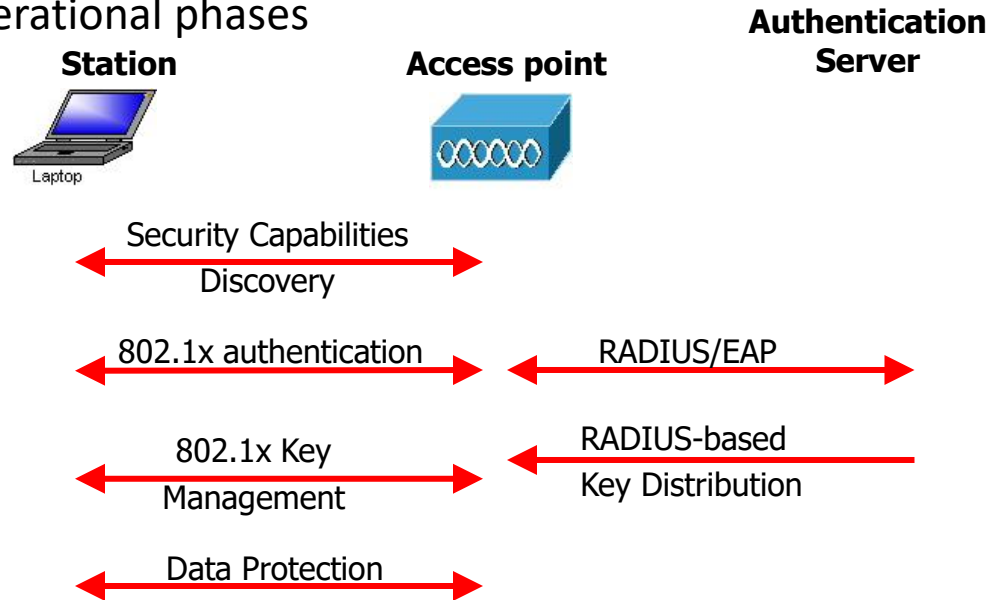
Robust Security Network

– Discovery message exchange



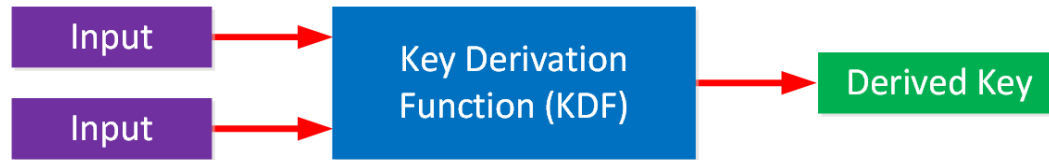
Robust Security Network

- Operational phases



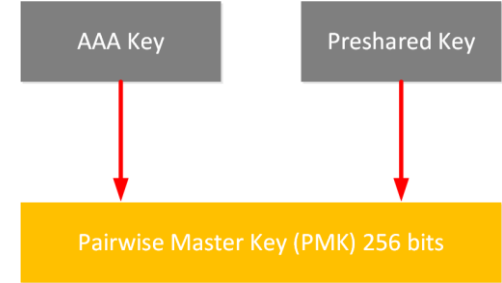
Key Derivation and Key Partitioning

- Key derivation is a process used in cryptography to generate one or more cryptographic keys from one or more values



- What is the advantages?

Key Partitioning :Pairwise Master Key (PMK)



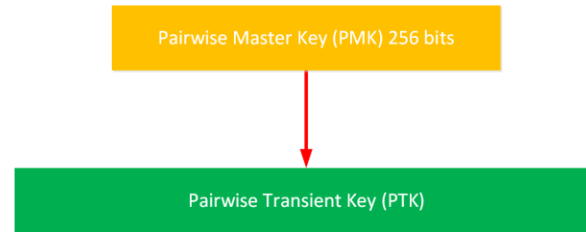
- In the context of **WPA2 security**, the **AAA Key** refers to a **key derived from the authentication process** when using a **RADIUS server** (part of the **802.1X authentication framework**)
- The pairwise master key (PMK) is a 256-bit key at the **top of the key hierarchy** and is used indirectly for **unicast traffic and the WPA 4-way handshake**.

The Pairwise Transient Key (PTK)

It is used for **encryption and integrity checks in unicast user data. It is also used for protecting the 4-way handshake.**

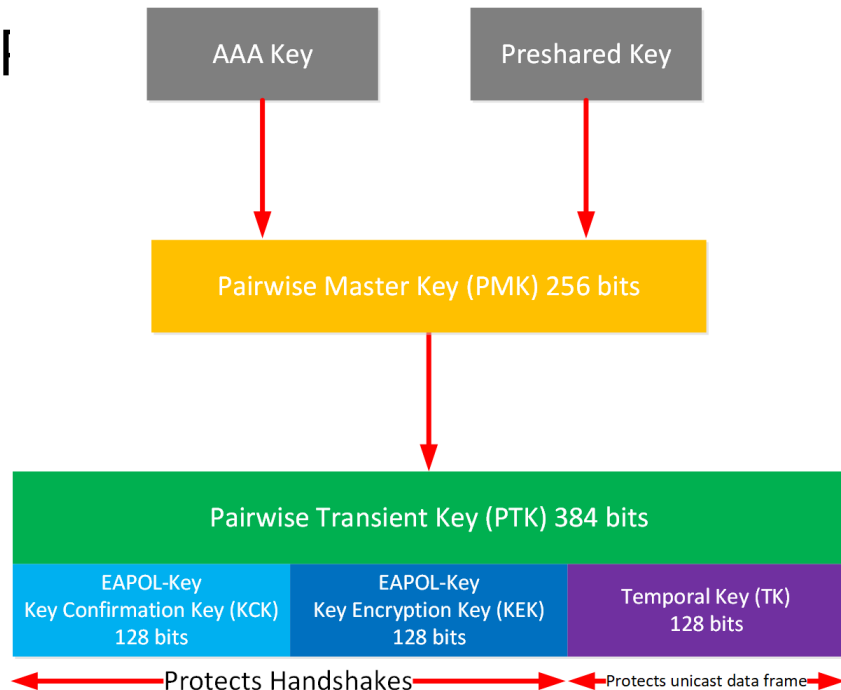
The PTK is derived by combining these attributes:

- PMK
- AP Nonce (Anonce)
- STA Nonce (Snonce)
- AP MAC address
- STA MAC address



AES-CCMP

- The PTK is 384 bits for AES-CCMP
 - EAPOL-Key Key Confirmation Key (KCK)
 - Integrity check
 - EAPOL-Key Key Encryption Key (KEK)
 - Encryption
 - Temporal Key (TK)
 - Integrity



Key Management and Establishment

- 802.1x key management



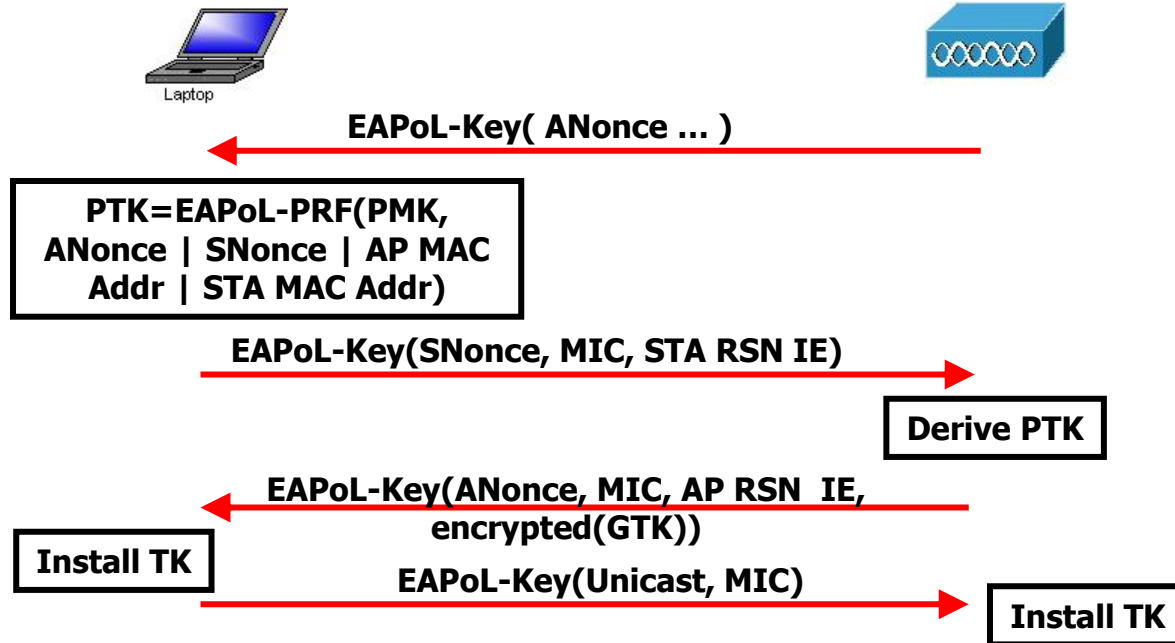
Use RADIUS to push PMK from
AS to AP

Use PMK and 4-way Handshake
To derive, bind, and verify PTK

Use Group Key Handshake to
send GTK from AP to station

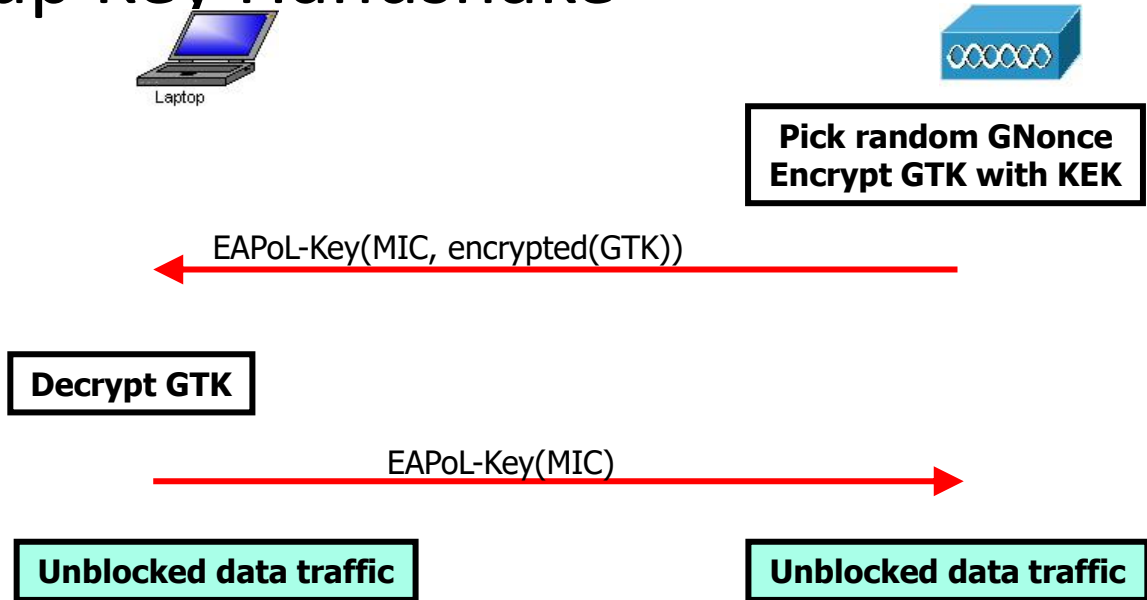
Key Management & Establishment

- 4-Way Handshake

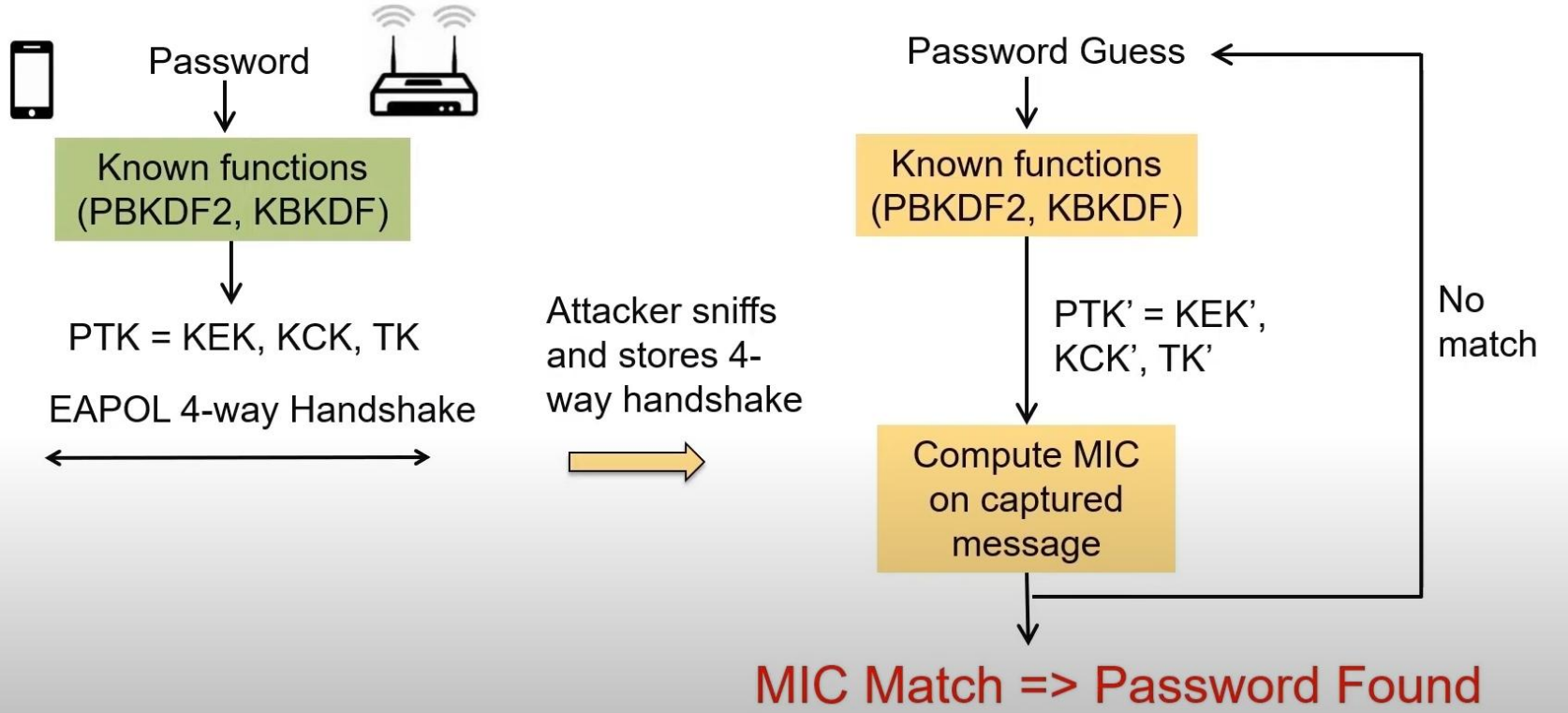


Key Management & Establishment

- Group Key Handshake

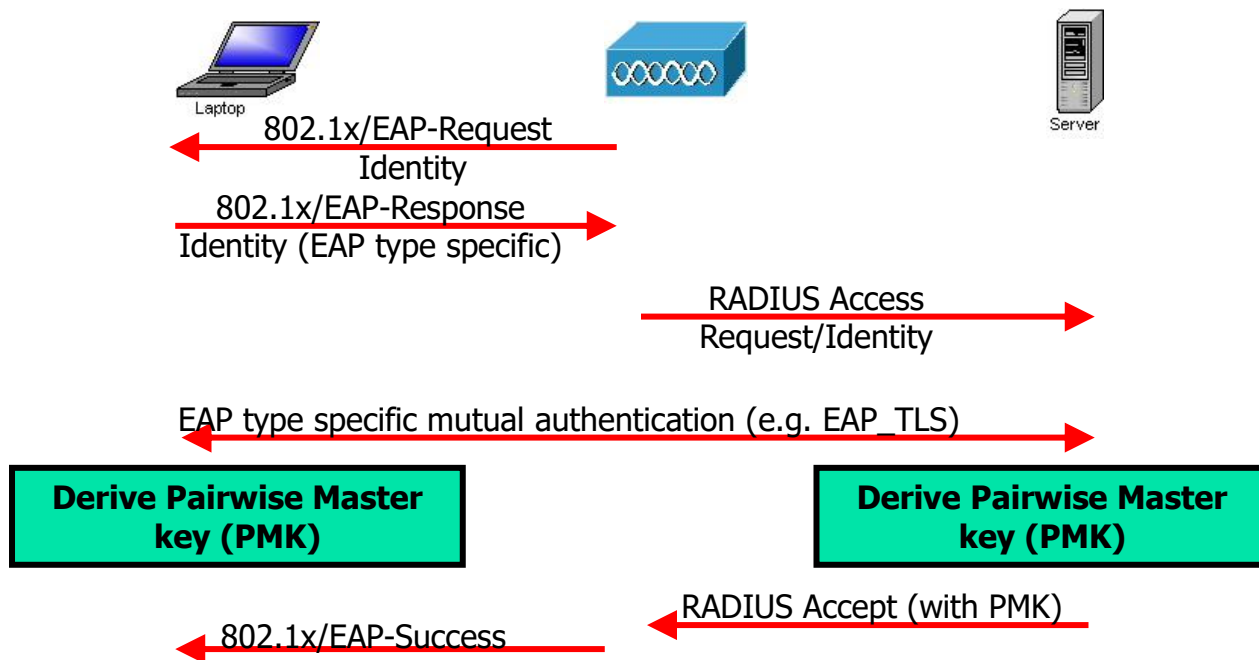


Offline Dictionary Attack



Authentication protocols

- Authentication overview



Authentication Protocols

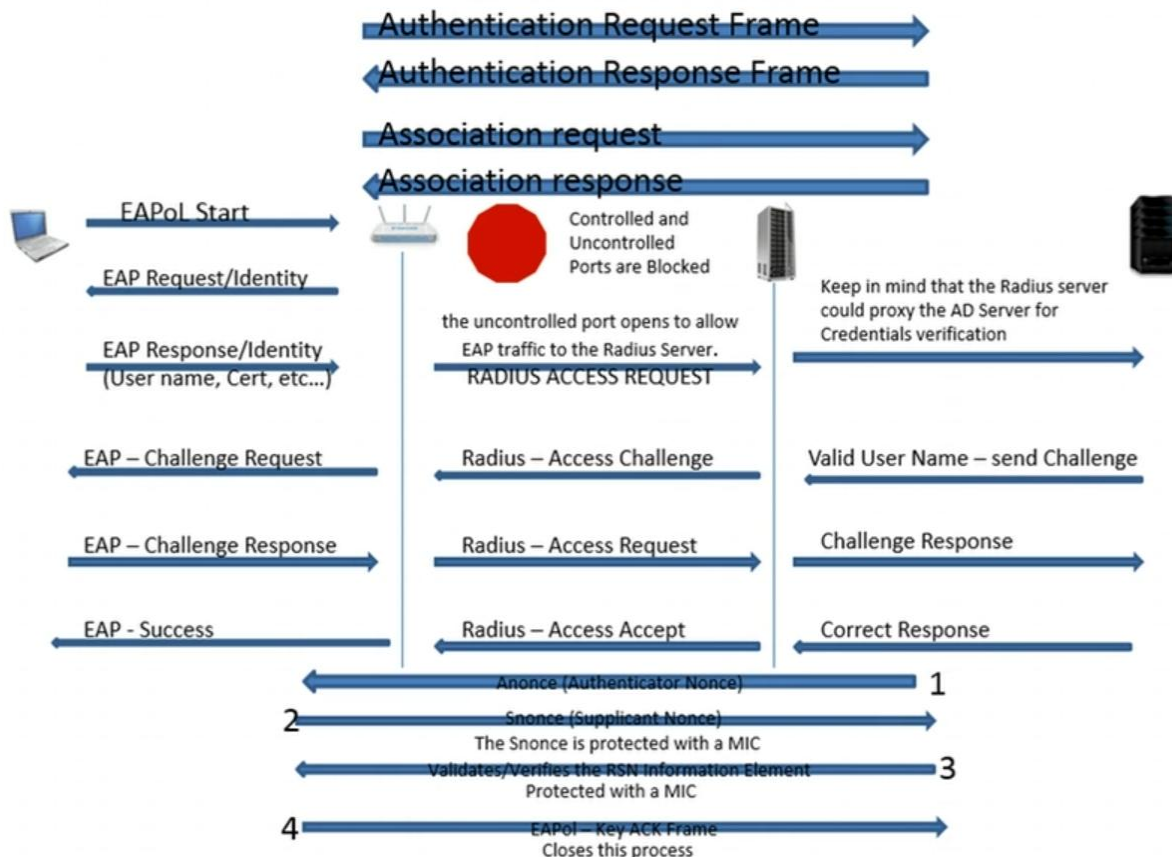
- EAP authentication: general approach
 - Used TLS to setup a secure tunnel
 - Inner authentication method is used for further authentication



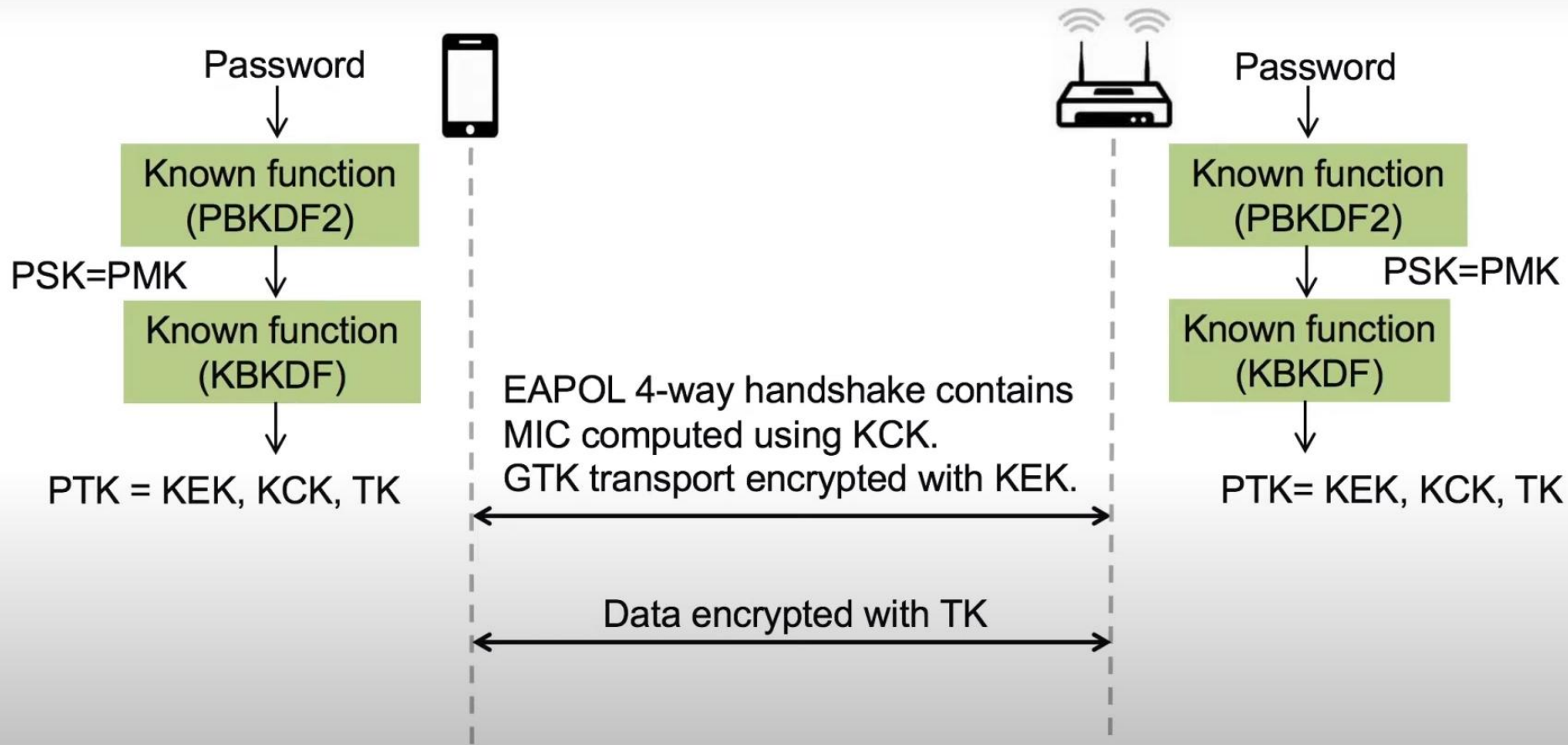
PMK = function of (nonces, {DH secret/session key})

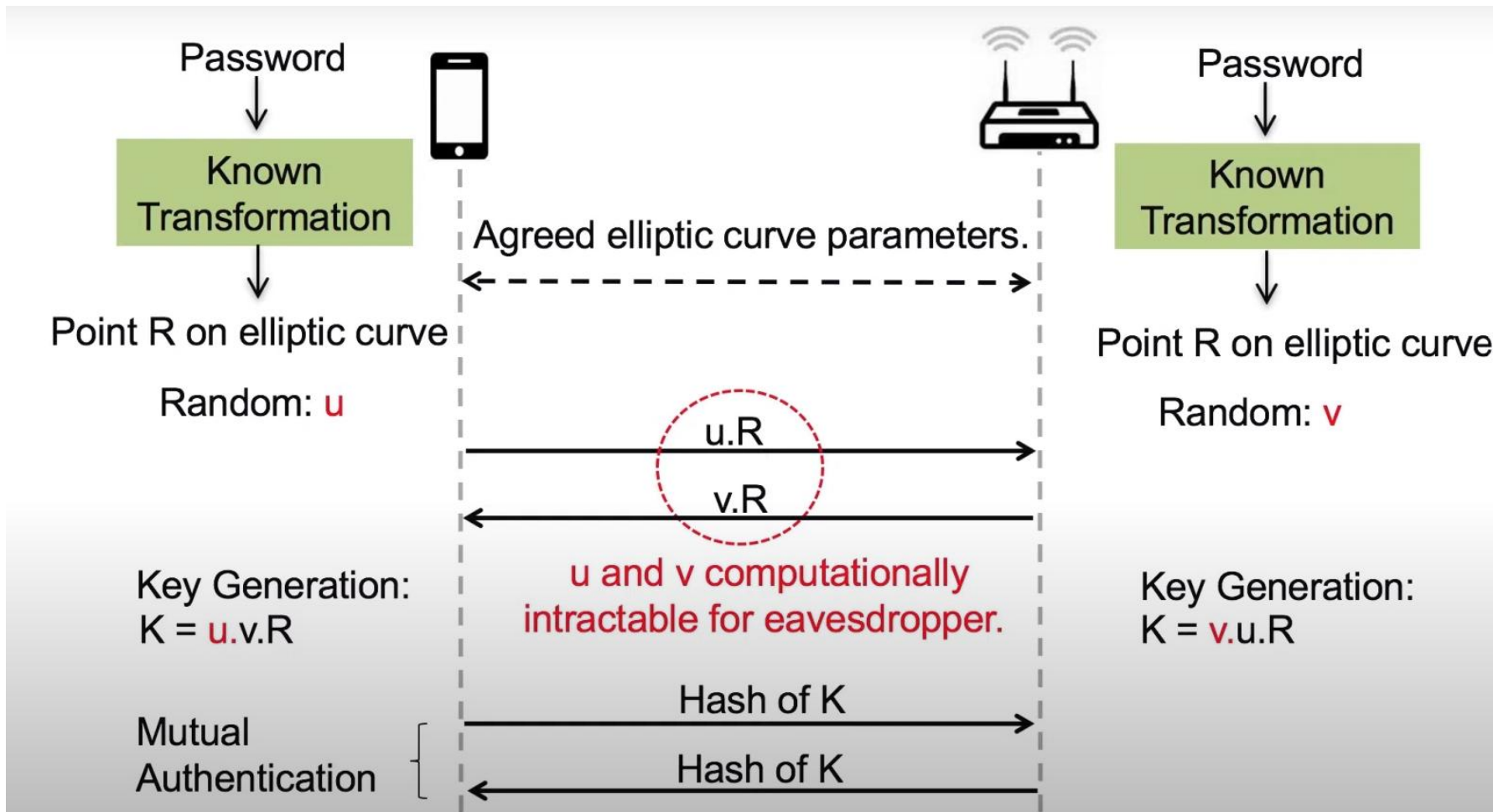
Review

Open System Authentication

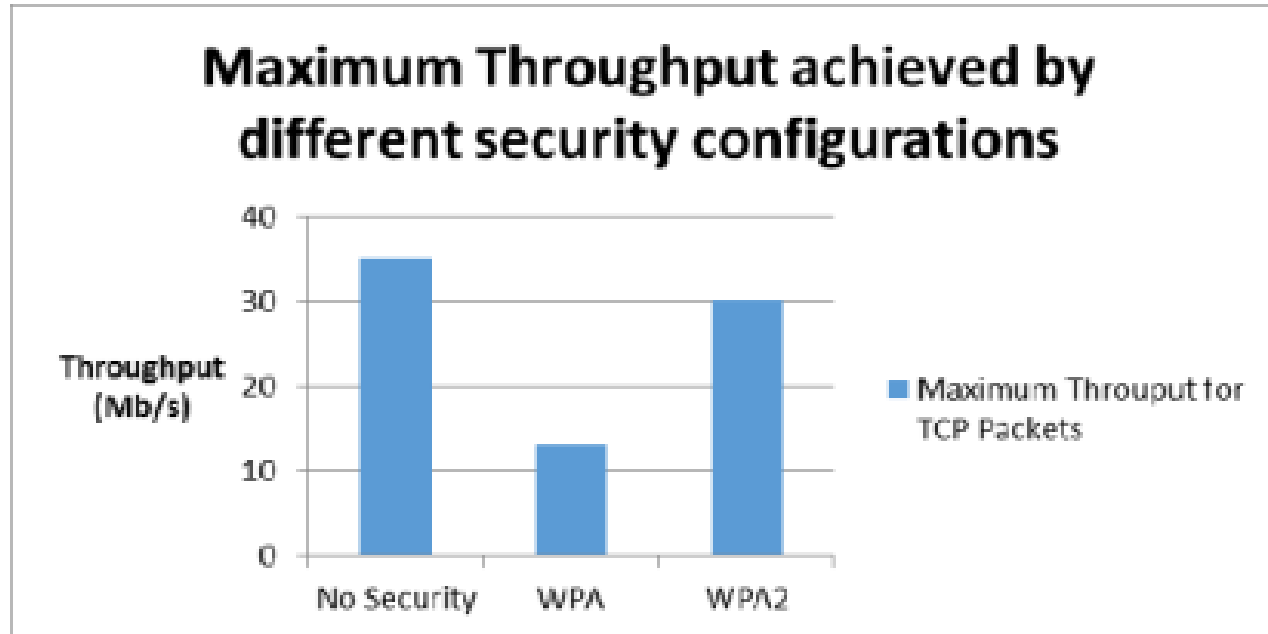


Complement

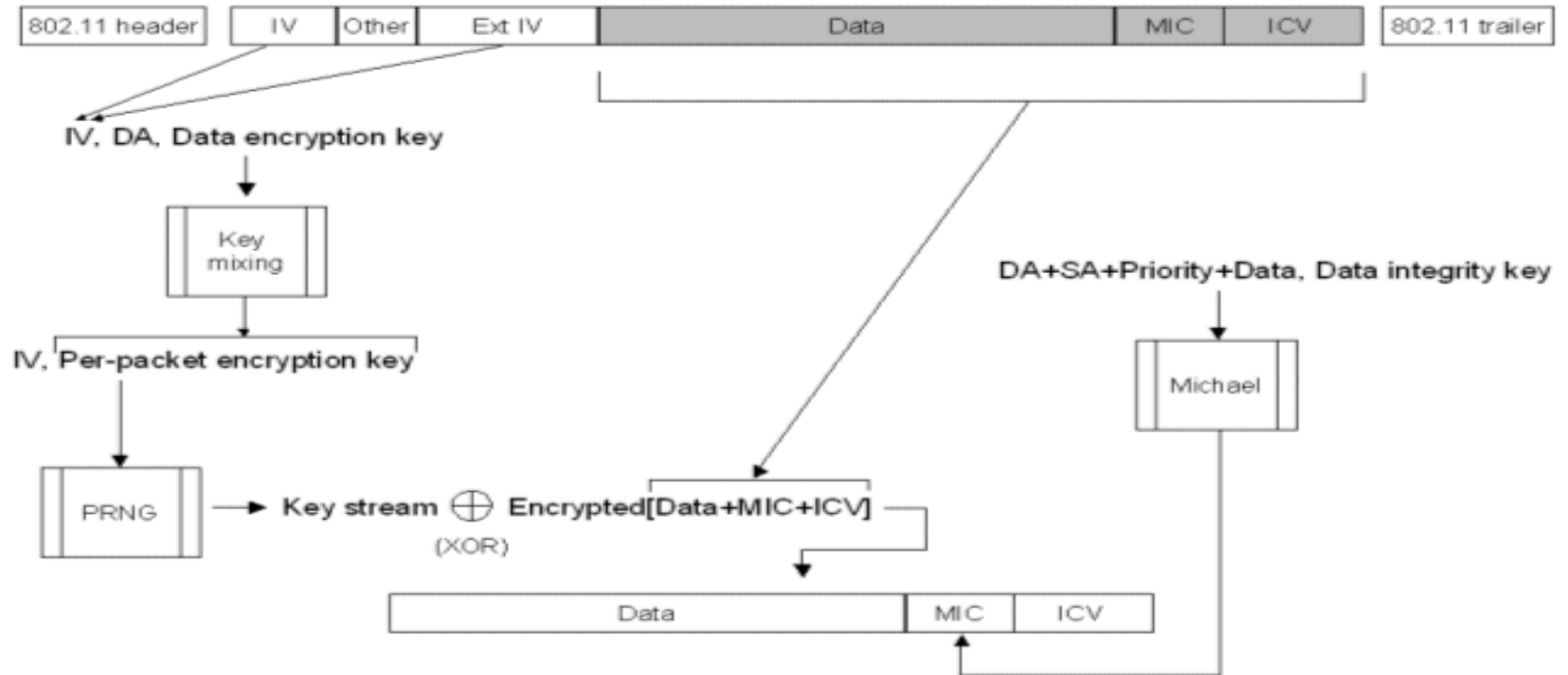




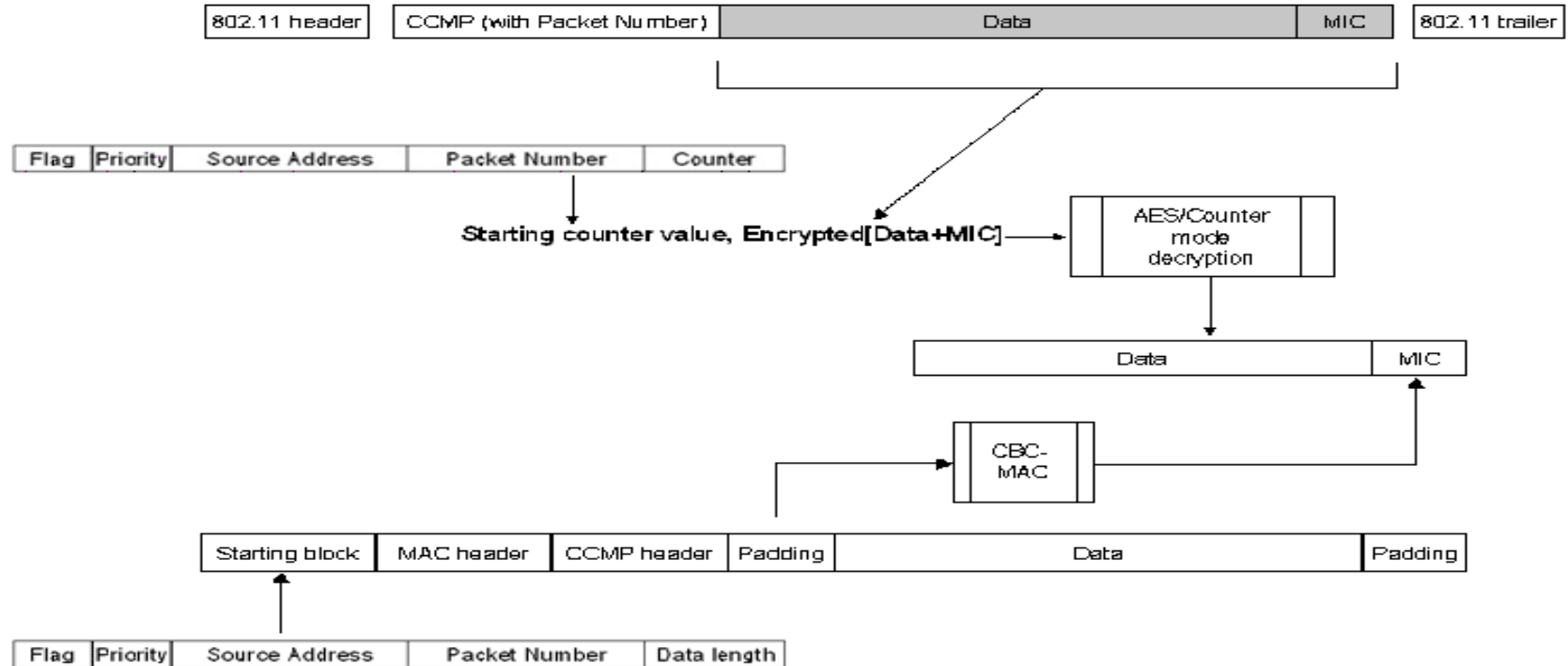
Bitrate



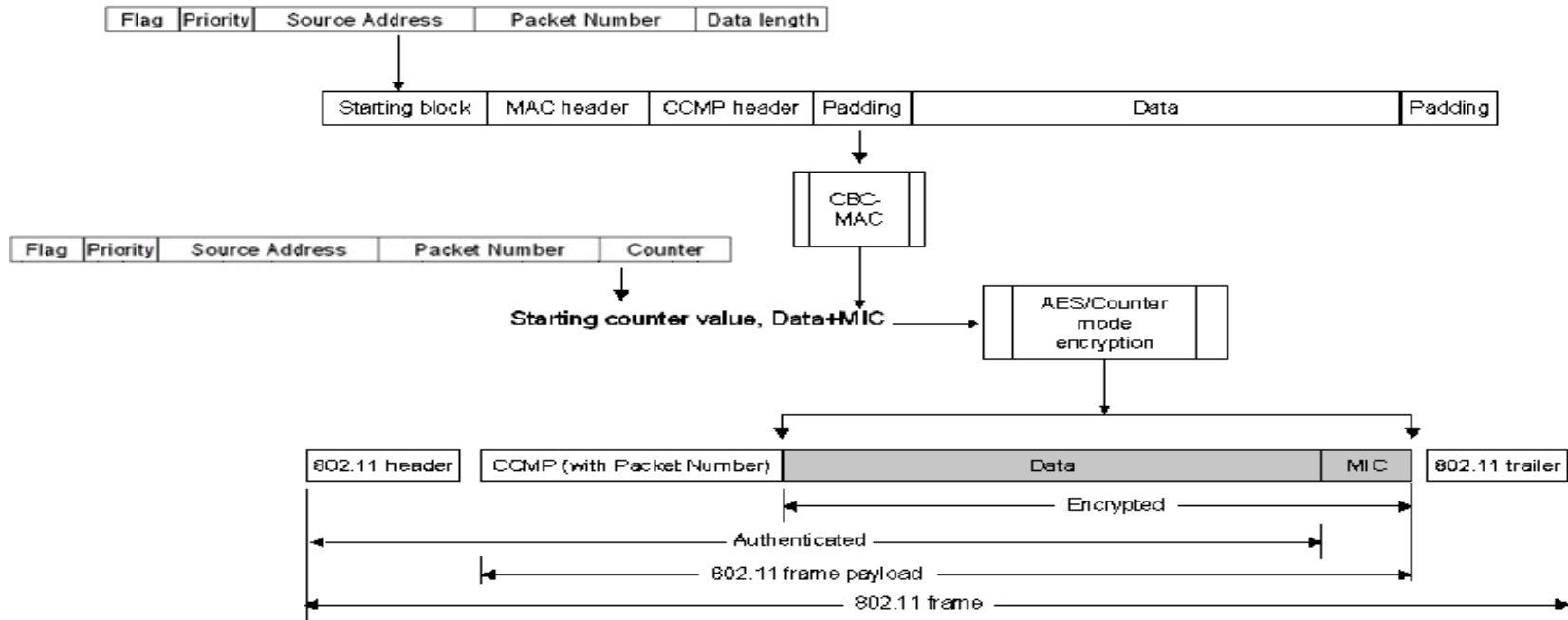
WPA Decryption



WPA2 Decryption



WPA2 Encryption



References

- <https://www.intel.com/content/www/us/en/support/articles/000006999/wireless/legacy-intel-wireless-products.html>
- <https://ieeexplore.ieee.org/stamp/stamp.jsp?tp=&arnumber=7506822>
- <https://networklessons.com/>
- https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/sec_usr_8021x/configuration/15-e/sec-usr-8021x-15-e-book/config-ieee-802x-pba.html?dtid=osscdc000283